

SECURITY REVIEW

NAF Reklamasjonssystem — security posture, controls,
and known limitations prepared for IT security review.

APPLICATION

NAF Reklamasjonssystem

LAST UPDATED

29 April 2026

NAF

Application: NAF Reklamasjonssystem

Last updated: 2026-04-29

Prepared for: IT security review

This document describes the security posture of the NAF Reklamasjonssystem. A professional developer or IT security reviewer should be able to understand the full security model from this document without reading the source code.

1. Overview

The NAF Reklamasjonssystem is an internal case management tool for handling customer complaints at NAF centres. It has two audiences:

- **Internal staff** (reklamasjonsansvarlig, senterleder, overordnet, admin): log in to view, manage, and respond to cases
- **Customers** (public): submit complaints via `/ny-reklamasjon`, and reply to agent emails via a token-protected portal at `/svar/[case_id]`

The application is hosted on Vercel (`naf-reklamasjon-next.vercel.app`) and uses Supabase for database, authentication, and file storage.

2. Data Inventory

Data type	Where stored	Who can access	Notes
Customer name, email, phone	Supabase PostgreSQL (eu-north-1)	Reklamasjonsansvarlig, senterleder (own centre), overordnet, admin	RLS enforced
Complaint description and details	Supabase PostgreSQL (eu-north-1)	Reklamasjonsansvarlig, senterleder (own centre), overordnet, admin	RLS enforced
Case messages (agent replies, customer replies)	Supabase PostgreSQL (eu-north-1)	Reklamasjonsansvarlig, senterleder (own centre), overordnet, admin	Internal notes never shown to customers
File attachments (photos, PDFs)	Supabase Storage (eu-north-1)	Reklamasjonsansvarlig, senterleder (own centre), overordnet, admin	Signed 60-minute download URLs; never publicly accessible
Session tokens	Supabase Auth — httpOnly cookies	Browser only	JWTs; expire per Supabase default
Reply tokens	Supabase PostgreSQL — <code>cases.reply_token</code>	Server-side only	UUID (122-bit entropy); never logged
Email content	SendGrid (transient)	Not stored by SendGrid after delivery	Transactional only
Rate limit counters	Upstash Redis (EU-West-1, Ireland)	Server-side only	IP-based keys, no PII stored

3. Third-Party Vendors

Vendor	Role	Data processed	Region
Supabase	Database, auth, file storage	All customer PII and case data	eu-north-1 (Stockholm, Sweden)
Vercel	Application hosting, serverless functions	Request/response data; env vars (encrypted at rest)	Global CDN; functions in closest region
SendGrid	Transactional email delivery	Customer email addresses, email body content	Global; transient only
Upstash	Rate limiting counter store	IP addresses (as rate limit keys, no PII)	EU-West-1 (Ireland)

Note: DPA (Data Processing Agreement) status with each vendor should be confirmed with NAF's legal/compliance team before production launch.

4. Authentication & Authorisation

Authentication

Supabase Auth handles all authentication. Users log in with email + password. Sessions are stored as httpOnly cookies (not accessible to JavaScript), refreshed automatically by the Supabase SSR client.

Role hierarchy

Four roles are defined in the `profiles.role` column:

Role	Access
<code>admin</code>	Everything, including user management
<code>overordnet</code>	Everything, including user management (same as admin)
<code>reklamasjonsansvarlig</code>	All cases across all centres; cannot manage users
<code>senterleder</code>	Only own centre's cases (RLS-enforced)

Row-Level Security (RLS)

All database tables have RLS enabled. Supabase enforces access at the database layer — application bugs cannot expose data from other centres.

The policies enforce role- and centre-aware access:

Table	SELECT	UPDATE
<code>cases</code>	Staff (admin/overordnet/reklamasjonsansvarlig): all rows. Senterleder: only rows where <code>cases.senter = profiles.senter</code> .	Same as SELECT for read access; <code>WITH CHECK</code> permits a senterleder to move a case out of their own centre via the in-app "Flytt"-action (the move is logged as an internal system message).
<code>messages</code>	Staff: all rows. Senterleder: only messages whose parent case belongs to their centre.	Insert allowed for any authenticated user (the public reply portal uses the service-role client and bypasses RLS).
<code>attachments</code>	Staff: all rows. Senterleder: only attachments whose parent case belongs to their centre.	Insert allowed where <code>uploader_id = auth.uid()</code> .
<code>pending_registrations</code>	Admin and overordnet only.	n/a
<code>profiles</code>	All authenticated users (needed to populate assignee dropdowns).	A user may update their own profile; admin and overordnet may update any.

Public flows (anonymous complaint submission, customer reply via reply-token) use the Supabase service-role client server-side, which bypasses RLS. The token itself gates access for the customer flow (see Public portal access below).

Public portal access

The customer reply portal (`/svar/[case_id]`) requires no login. Access is controlled by a `reply_token` — a UUID (122 bits of entropy) stored on each case. The token is:

- Included in outbound agent email as a URL parameter
- Validated server-side on every request using `crypto.timingSafeEqual` (prevents timing attacks)
- Never rotated after use (customers may reply multiple times from the same email link)
- Validated with the same error message whether the case doesn't exist or the token is wrong (prevents case enumeration)

5. Security Controls

Control	Where	Why
Security headers	<code>next.config.ts</code>	CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, COOP, CORP, Permissions-Policy on all responses
Content Security Policy	<code>next.config.ts</code>	Restricts which scripts, styles, connections the browser will allow; prevents XSS data exfiltration
Rate limiting	<code>proxy.ts</code> middleware	Prevents abuse of unauthenticated endpoints; 5 req/10min on reply API, 3 req/hour on complaint submission
Distributed rate limit store	Upstash Redis (EU)	In-memory counters don't work across Vercel's serverless instances; Redis ensures limits are globally enforced
UUID reply tokens	<code>cases.reply_token</code>	122-bit entropy token gates customer portal access; not guessable
Timing-safe token comparison	<code>app/api/customer-reply/route.ts</code> , <code>app/api/attachments/upload/route.ts</code>	<code>crypto.timingSafeEqual</code> prevents timing side-channel attacks on token validation
Token guard on file uploads	<code>app/api/attachments/upload/route.ts</code>	Portal file uploads require valid <code>reply_token</code> ; prevents arbitrary file uploads
Input validation	All API routes	Content length enforced (5,000 chars max for messages), file type (JPG/PNG/PDF only), file size (10 MB max)
HTML escaping	<code>app/api/send-email/route.ts</code>	All customer-provided content is HTML-escaped before inclusion in emails
Service-role client server-only	<code>lib/admin-api.ts</code>	<code>adminDb</code> (Supabase service role key) is only imported in server-side code; never bundled to the browser
Internal notes hidden from customers	<code>app/svar/[case_id]/page.tsx</code> , message queries	<code>type = 'internal'</code> messages are explicitly excluded from all customer-facing queries
Auth middleware	<code>proxy.ts</code>	All routes under <code>/saksbehandling</code> , <code>/admin</code> , <code>/eksport</code> redirect to login if no valid session
HTTPS enforced	Vercel platform + <code>upgrade-insecure-requests</code> CSP directive	All traffic encrypted in transit

Control	Where	Why
Centre-aware RLS	<code>cases_select</code> , <code>cases_update</code> , <code>messages_select</code> policies	Senterleder cannot read or modify cases or messages outside their own centre, even via direct REST calls with their JWT
Audit log on case transfers	<code>transferCase</code> in <code>app/saksbehandling/page.tsx</code>	Moving a case to another centre writes an internal system message recording the actor, source, destination, and reason
Centre value enforced at column level	<code>cases_senter_valid</code> CHECK constraint on <code>cases.senter</code>	The sender column may only contain one of the 44 canonical NAF centre names (or NULL). Enforced by PostgreSQL regardless of which client writes — defends against direct REST writes attempting to set arbitrary or empty sender values
Service-role audited transfer endpoint	<code>app/api/case-transfer/route.ts</code>	Centre transfers go through a server-side endpoint that validates role, ownership (senterleder may only transfer cases from own centre), and writes the audit message in the same call

6. Known Limitations

Limitation	Severity	Notes
Hosted on <code>vercel.app</code> (not a NAF-controlled domain)	Low	Custom domain (<code>reklamasjon.naf.no</code> or similar) is planned post-review
CSP uses <code>unsafe-inline</code> for scripts	Low	Required by Next.js hydration. Nonce-based CSP is the future enhancement; current CSP still blocks all external script injection
CSP uses <code>unsafe-eval</code> for scripts	Low	Required by Supabase Realtime (uses <code>new Function</code> internally). Will be removed if Supabase Realtime removes this requirement
No WAF (Web Application Firewall)	Low	Vercel's platform provides DDoS protection. A WAF (e.g. Cloudflare) is a future enhancement
Rate limiting fails open	Accepted	If Upstash is unavailable, requests are allowed through. Availability prioritised over hard blocking for a complaint tool
Partial audit log	Low	Case transfers (centre changes) and assignments are logged as internal system messages on the case timeline. Status, priority, and field-level edits are not yet logged to a separate audit trail. Planned as a future enhancement

7. Dependency Audit

Last run: 2026-04-23

```
uuid <14.0.0
Severity: moderate
Missing buffer bounds check in v3/v5/v6 when buf is provided
GHSA-w5hq-g745-h8pq

Transitive via exceljs. 2 moderate severity vulnerabilities total.
```

Resolved vulnerabilities

Package	Advisory	Severity	Resolution
xlsx	GHSA-4r6h-8v6p-xvw6 (Prototype Pollution), GHSA-5pgg-2g8v-p4x9 (ReDoS)	HIGH	Replaced with exceljs

Accepted vulnerabilities

Package	Advisory	Severity	Reason accepted
uuid (via exceljs)	GHSA-w5hq-g745-h8pq	Moderate	Transitive dependency; not directly reachable from user input. Fixing requires downgrading exceljs to a breaking version. Monitored for upstream fix.

8. Reporting a Vulnerability

See `/.well-known/security.txt` for contact information. Please report security vulnerabilities by email. Do not open a public GitHub issue for security findings.